سیلابس درسی · جلسهٔ ۴ از ۵

# امنیت و ارزیابی عامل‌های کدنویسی شهودی

اعتماد مؤثر (Effective Trust): از هفت ستون امنیت تا سنجش کیفیت درون جعبهٔ شیشه‌ای

**مدت جلسه:** ۱۸۰ دقیقه **سطح:** پیشرفته

**منبع اصلی:** Vibe Coding Agent Security and Evaluation — سوکراتیس کارتاکیس و همکاران

## فهرست این سیلابس


1. معرفی جلسه
2. اهداف یادگیری
3. پیش‌نیازها و آمادگی فنی
4. مفاهیم کلیدی و واژه‌نامه
5. زمان‌بندی دقیق جلسه
6. کارگاه عملی
7. ارزشیابی و تکلیف
8. منابع و مطالعهٔ تکمیلی


## ۱. معرفی جلسه

سه جلسهٔ نخست عامل (agent) را **توانمند** کردند: مهار (harness) ساختیم، ابزار (tool) وصل کردیم، دانش رویه‌ای دادیم. جلسهٔ چهارم دو پرسشی را می‌پرسد که پیش از هر انتشار تولیدی باید پاسخ داشته باشند:

**دو محور بازتعریف اعتماد**

**امنیت** به شما می‌گوید آیا عامل درون مرز ماند.
**ارزیابی** (evaluation) به شما می‌گوید آیا آنچه درون آن مرز اتفاق افتاد، ارزش انتشار دارد.

عاملِ کدنویسی‌شده می‌تواند همهٔ وارسی‌های امنیتی را پاس کند و همچنان قصد (intent) توسعه‌دهنده را بنیاداً بد بفهمد، قراردادهای پروژه را نادیده بگیرد، یا تجربهٔ کاربر را بی‌سروصدا خراب کند.

در نرم‌افزار قطعی، اعتماد صفر و یکی است: کد کامپایل می‌شود، تست‌ها (test) پاس می‌شوند، اعتبارنامه‌های (credential) ایستا معتبرند. در سامانهٔ عامل‌محور، نیروی کاری خودگردانی داریم که **اختیار** (authority) **محیطی** (dynamic) دارد: کد تولیدشده را اجرا می‌کند، به رابط‌های داخلی حساس دسترسی می‌گیرد و محیط تولید را پویا تغییر می‌دهد. اینجا اعتماد دیگر دروازه‌ای نیست که یک‌بار هنگام دیپلوی (deploy) از آن رد شوید؛ باید پیوسته کسب، راستی‌آزمایی و بر پایهٔ زمینهٔ رانتایم (runtime) اعمال شود.

## ۲. اهداف یادگیری

| # | هدف یادگیری | سطح شناختی |
|---|---|---|
| ۱ | تفاوت امنیت و ارزیابی را به‌عنوان دو محور مستقل اعتماد توضیح دهد و برای هرکدام مثال بزند. | فهم |
| ۲ | هفت ستون معماری امنیت عامل را نام ببرد و مالک سازمانی هر ستون را مشخص کند. | دانش و تحلیل |
| ۳ | مخاطرهٔ بسته‌های توهمی را توضیح دهد و زنجیرهٔ دفاعی مقابله با آن را طراحی کند. | کاربرد |
| ۴ | دو الگوی خطا امنیتی کد تولیدشده (اعتماد بیش‌ازحد به مرورگر، رهاکردن پشتیبان) را در یک نمونه تشخیص دهد. | تحلیل |
| ۵ | مسئلهٔ «معاون گیج `(Confused Deputy)`» را شرح دهد و راه‌حل هویت `(identity)` عامل‌محور و کاهش دامنهٔ به‌هنگام `(JIT downscoping)` را به‌کار ببندد. | کاربرد |
| ۶ | مفهوم «تفاوت‌نمای شهودی `(Vibe Diff)`» را توضیح دهد و بگوید چرا دکمهٔ سادهٔ تأیید کافی نیست. | تحلیل و ارزشیابی |
| ۷ | نقش سه‌گانهٔ تیم قرمز، آبی و سبز را در عملیات امنیتی عامل‌محور تفکیک کند. | فهم و تحلیل |
| ۸ | «انحراف قصد `(Intent Drift)`» و «زوال اعتماد `(Trust Decay)`» را تعریف کند و سازوکار قطع‌کننده و نقطهٔ بازگشت را طراحی کند. | کاربرد |
| ۹ | سه دلیل متمایزبودن ارزیابی عامل‌های کدنویسی شهودی `(Vibe coding)` را بیان کند. | فهم |
| ۱۰ | هفت بُعد ارزیابی را نام ببرد و برای هر بُعد روش سنجش مناسب را انتخاب کند. | ارزشیابی |
| ۱۱ | از پیشوند نشست `(session)` به‌عنوان سنجهٔ قصد استفاده کند و هم‌گرایی نشست `(Session convergence)` را به‌جای درستی تک‌نوبتی بسنجد. | ایجاد |

# ۳. پیش‌نیازها و آمادگی فنی

## دانش پیش‌نیاز

- مفهوم مهار و اجزای آن از جلسهٔ اول؛ به‌ویژه سندباکس، قلاب‌ها (hook) و رصدپذیری (observability).
- مفاهیم MCP و A2A از جلسهٔ دوم.
- نردبان اختیار (Read) و چهار حالت شکست مهارت (skill) از جلسهٔ سوم.
- آشنایی پایه با مفاهیم امنیت نرم‌افزار: احراز هویت، مجوزدهی، کمترین امتیاز (least privilege).

## آمادگی فنی پیش از کلاس

- دسترسی به یک پروژهٔ آزمایشی که بتوان روی آن پویش امنیتی اجرا کرد.
- یک ابزار تحلیل ترکیب نرم‌افزار یا پویش وابستگی‌ها (dependency) (هر ابزاری که در تیم استفاده می‌کنید).
- نمونه‌ای از خروجی واقعی عامل که در پروژهٔ خودتان تولید شده و هنوز بازبینی امنیتی نشده است.

> **هشدار اخلاقی و قانونی**
>
> تمرین‌های تیم قرمز این جلسه فقط روی **محیط و پروژهٔ آزمایشی خودتان** انجام می‌شوند. هیچ تمرینی نباید علیه سامانهٔ تولیدی، سامانهٔ شخص ثالث یا زیرساختی که مجوز کتبی تست آن را ندارید اجرا شود. این قاعده را در دقیقهٔ اول کلاس اعلام کنید.

# ۴. مفاهیم کلیدی و واژه‌نامه

| اصطلاح | معادل انگلیسی | تعریف کوتاه |
|---|---|---|
| اعتماد مؤثر | Effective Trust | سنجهٔ پیوسته‌ای که در زنجیرهٔ تأمین، هویت، رفتار رانتایم و پیوندهای زمینه‌ای عامل ارزیابی می‌شود. |
| زمینه به‌مثابه محیط (Context-as-a-Perimeter) | Context-as-a-Perimeter | جایگزین مدل «هویت به‌مثابه محیط»؛ مجوز بر پایهٔ زمینهٔ رانتایم تعیین می‌شود نه صرفاً نقش ایستا. |
| سندباکس زودگذر (Ephemeral sandbox) | Ephemeral sandbox | محیط ایزولهٔ سطح هسته که میان اجراها وضعیتش کاملاً بازنشانی می‌شود. |
| بستهٔ توهمی (Hallucinated package) | Hallucinated package | نام بسته‌ای که مدل می‌سازد و وجود ندارد؛ مهاجم همان نام را با بدافزار منتشر می‌کند. |
| سوءاستفاده از نام توهمی (Slopsquatting) | Slopsquatting | حملهٔ زنجیرهٔ تأمین مبتنی بر انتشار بدافزار با نام‌های ساختگیِ محتمل. |
| حکمرانی خروج شبکه (Egress governance) | Egress governance | کنترل ترافیک خروجی عامل؛ دسترسی غیرتعاملی و از راه کش (cache) یا پیش‌پالایش‌شده. |
| جعل سرور ابزار (MCP spoofing) | MCP spoofing | سروری جعلی که خود را ابزار مشروع جا می‌زند تا پیلود (payload) مخرب تزریق یا امتیاز بیش‌ازحد بگیرد. |
| معاون گیج | Confused Deputy | عاملی با امتیاز بیش‌ازحد که فریب می‌خورد و فرمان غیرمجاز را به نیابت مهاجم اجرا می‌کند. |
| اختیار محیطی صفر (Zero Ambient Authority) | Zero Ambient Authority | عامل هرگز امتیازهای گستردهٔ توسعه‌دهنده را به ارث نمی‌برد. |
| کاهش دامنهٔ به‌هنگام | JIT downscoping | صدور توکن (token) تازه و بسیار محدود برای همان کار مشخص، که دقیقاً با پایان کار منقضی می‌شود. |

| اصطلاح | معادل انگلیسی | تعریف کوتاه |
| --- | --- | --- |
| تفاوت‌نمای شهودی | Vibe Diff | ترجمهٔ کد تولیدشده به خلاصه‌ای به زبان ساده، پیش از تأیید انسانی کنش پرمخاطره. |
| پیلود مخرب نامرئی (Invisible payload) | Invisible payload | نویسه‌های با عرض صفر یا هم‌ریخت که در کد پنهان می‌شوند و از بازبینی انسانی می‌گریزند. |
| تحلیل رفتاری عامل (ABA) | ABA | مبناگیری مسیرهای اجرای مورد انتظار و تشخیص ناهنجاری‌های ویژهٔ عامل‌ها. |
| صورت‌ریز اجزای رانتایم (AgBOM) | AgBOM | سیاههٔ پویای ابزارها، مدل‌ها و منابع دادهٔ فعال عامل در هر لحظه. |
| قرنطینهٔ باحالت (Stateful quarantine) | Stateful quarantine | سلب دسترسی ابزار بدون کشتن فرایند، تا حافظهٔ کوتاه‌مدت برای تحلیل قانونی سالم بماند. |
| مسیر شهودی (Vibe Trajectory) | Vibe Trajectory | نمای زمانی و یکپارچهٔ گام‌های شناختی عامل، از پرامپت تا کنش واقعی. |
| انحراف (drift) قصد | Intent Drift | دنبال‌کردن زیرهدف‌هایی که از قصد اولیهٔ انسان فاصله می‌گیرند. |
| زوال اعتماد | Trust Decay | اصل کاهش‌پذیری اعتماد؛ اعتماد دارایی مستهلک‌شدنی است، نه وضعیت دائمی. |
| انکار کیف پول (Denial of Wallet) | Denial of Wallet | حمله‌ای که با راه‌انداختن حلقه‌های بی‌پایان پرهزینه، صورت‌حساب سازمان را منفجر می‌کند. |
| شکاف کم‌مشخصگی (Underspecification Gap) | Underspecification Gap | پرامپت (prompt) زبان طبیعی کاربر ذاتاً ناقص است؛ کار اول ارزیابی، سنجش بازسازی درست مشخصات (spec) نانوشته است. |
| هم‌گرایی نشست | Session convergence | سنجهٔ اصلی موفقیت: آیا کاربر به چیزی که می‌خواست رسید و در چند نوبت؟ |

# ۵. زمان‌بندی دقیق جلسه

**00:00 – 00:15**

**گشایش: چرا اعتماد صفر و یکی دیگر کار نمی‌کند**

دو محور امنیت و ارزیابی، مفهوم اعتماد مؤثر، و گذار از هویت به زمینه (context) به‌عنوان محیط. اسلاید ۱–۵

**00:15 – 00:40**

**هفت ستون معماری امنیت عامل**

زیرساخت، داده، مدل، برنامه و رانتایم، هویت، رصدپذیری، حاکمیت — با مالک سازمانی و تهدید اصلی هر ستون. اسلاید ۶–۱۱

**00:40 – 01:05**

**سندباکس (sandbox) و دفاع زنجیرهٔ تأمین**

حلقهٔ شهودی و چرایی ایزوله‌سازی، بسته‌های توهمی و سوءاستفاده از نام، و حکمرانی خروج شبکه. اسلاید ۱۲–۱۷

**01:05 – 01:15**

**استراحت اول**

۱۰ دقیقه.

**01:15 – 01:35**

**امن‌سازی منطق برنامه و هویت**

دو الگوی خطا کد تولیدشده، آشتی اصطکاک ویرایشگر با اعمال سخت‌گیرانه در خط لوله، جعل ابزار، معاون گیج و اختیار محیطی صفر. اسلاید ۱۸–۲۵

**01:35 – 01:55**

**کارگاه ۱: بازبینی امنیتی خروجی عامل**

فراگیران روی کد تولیدشدهٔ واقعی، دو الگوی خطا و نقاط اختیار بیش‌ازحد را پیدا می‌کنند. اسلاید ۲۶

**01:55 – 02:20**

**سه‌گانهٔ قرمز، آبی و سبز و رصدپذیری**

پیلودهای مخرب نامرئی، تزریق «حس‌وحال خصمانه»، تحلیل رفتاری، قرنطینهٔ باحالت، مسیر (trajectory) شهودی و قطع‌کننده. اسلاید ۲۷–۳۴

**02:20 – 02:30**

**استراحت دوم**

۱۰ دقیقه.

**02:30 – 02:55**

**ارزیابی: چرا متفاوت است و چه چیزی را می‌سنجیم**

سه قید (constraint) یکتا، و هفت بُعد ارزیابی در دو گروه کاربرمحور و درونی، به‌همراه محور عرضی ایمنی. اسلاید ۳۵–۴۰

**02:55 – 03:10**

**چگونه ارزیابی کنیم**

هفت روش سنجش، نگاشت روش به بُعد، بنچمارک‌های (benchmark) استاندارد و دام بیش‌برازش، و رصدپذیری به‌عنوان پیش‌شرط. اسلاید ۴۱–۴۶

**03:10 – 03:20**

**نکته‌های کاربردی و جمع‌بندی**

پیشوند نشست به‌عنوان سنجه، داوری مصنوع رندرشده، هم‌گرایی نشست، و استخراج اصلاح‌های کاربر به‌عنوان دادهٔ برچسب‌خورده. اسلاید ۴۷–۵۰

# ۶. کارگاه عملی

## کارگاه ۱ — بازبینی امنیتی خروجی عامل (۲۰ دقیقه، گروه دونفره)

هر گروه روی نمونه‌ای از کد تولیدشدهٔ عامل (ترجیحاً از پروژهٔ خودشان) این سیاهه را اجرا می‌کند:

1. **اعتماد به سمت کاربر:** آیا کلید، اعتبارسنجی گذرواژه یا پرچم نشست کاربر در سمت مرورگر رها شده است؟
2. **پشتیبان رهاشده:** آیا کنترل دسترسی سطح ردیف یا رد پیش‌فرض فعال است، یا فقط اتصال برقرار شده؟
3. **وابستگی‌ها:** آیا همهٔ بسته‌ها واقعاً وجود دارند، از منبع معتبرند و نسخه‌شان قفل شده است؟
4. **دامنهٔ اختیار:** عامل با چه هویتی و چه مجوزهایی این کد را اجرا کرده است؟ کدام مجوزها لازم نبودند؟

**معیار پذیرش کارگاه ۱**

هر گروه باید دست‌کم **یک یافتهٔ واقعی** و **یک اصلاح مشخص** ارائه کند. یافته‌ای که به «شاید بهتر باشد امن‌تر بنویسیم» ختم شود، پذیرفته نیست؛ باید فایل، خط و اصلاح مشخص باشد.

## کارگاه ۲ — نوشتن یک تفاوت‌نمای شهودی (۱۵ دقیقه، انفرادی)

یک قطعه کد تولیدشدهٔ پرمخاطره به فراگیران داده می‌شود (مثلاً مهاجرت پایگاه داده یا تغییر پیکربندی دسترسی). هر نفر باید در حداکثر پنج جملهٔ ساده بنویسد که این کد **دقیقاً** چه می‌کند و چه چیزی برگشت‌ناپذیر است. سپس متن‌ها مقایسه می‌شوند: هر جایی که دو نفر برداشت متفاوتی داشته باشند، نقطه‌ای است که تأیید انسانی بدون تفاوت‌نما خطرناک بوده است.

## کارگاه ۳ — طراحی مجموعهٔ ارزیابی (۱۵ دقیقه، گروه سه‌نفره)

هر گروه برای یک قابلیت واقعی عامل، مجموعه‌ای از سنجه‌ها (`rubric`) طراحی می‌کند که دست‌کم چهار بُعد را پوشش دهد:

- **رضایت قصد:** معیارهای پذیرش مشتق‌شده از دو پیام نخست کاربر.
- **درستی کارکردی:** کدام تست‌ها باید پاس شوند و چطور از حذف یا جعل تست جلوگیری می‌کنید؟
- **کیفیت مسیر:** عامل باید پیش از ویرایش چه فایل‌هایی را خوانده باشد؟
- **رفتار خودترمیمی:** وقتی تست شکست می‌خورد، رفتار قابل‌قبول چیست و رفتار غیرقابل‌قبول کدام است؟

## تمرین کلاسی — تشخیص انحراف قصد (۱۰ دقیقه)

مدرس سه مسیر اجرای نمونه را می‌خواند (خلاصه‌شده). کلاس باید بگوید کدام‌یک انحراف قصد دارد و در کدام گام باید قطع‌کننده فعال می‌شد. نمونهٔ کلاسیک: پرامپت «پرس‌وجوی پایگاه داده را بهینه کن» که به تلاش برای نصب یک کتابخانهٔ نمایه‌سازی تازه و غیرمجاز منحرف می‌شود.

# ۷. ارزشیابی و تکلیف

| مؤلفه | سهم | شرح و معیار نمره‌دهی |
|---|---|---|
| گزارش بازبینی امنیتی | ۳۰٪ | یافته‌های واقعی روی کد تولیدشده، دسته‌بندی‌شده بر پایهٔ هفت ستون، با اصلاح مشخص برای هر یافته. |
| طرح مهار مخاطره | ۲۵٪ | یک صفحه: برای پرمخاطره‌ترین گردش‌کار (workflow) عاملی پروژه‌تان، سندباکس، دامنهٔ هویت، نقاط تأیید انسانی و سازوکار بازگشت را طراحی کنید. |
| مجموعهٔ ارزیابی | ۳۰٪ | پوشش (coverage) دست‌کم چهار بُعد از هفت بُعد، با روش سنجش متناسب برای هر بُعد و توضیح اینکه چرا این روش برای این بُعد درست است. |
| تحلیل اصلاح‌های کاربر | ۱۵٪ | جمع‌آوری دست‌کم ده مورد «نه، این‌طور نه» از نشست‌های واقعی خودتان، خوشه‌بندی دستی، و نام‌گذاری سه حالت شکست نظام‌مند. |

## تکلیف تا جلسهٔ بعد

1. برای ریپو (repository) خودتان یک گاردریل (guardrail) قطعی (deterministic) (قلاب پیش از کامیت (commit) یا وارسی در خط لوله) فعال کنید که دست‌کم یکی از دو الگوی خطا را بگیرد.
2. ده نشست اخیرتان با عامل را مرور کنید و اصلاح‌های خودتان را استخراج و دسته‌بندی کنید.
3. مقالهٔ ترجمه‌شدهٔ این جلسه را بخوانید؛ بخش ارزیابی در کلاس فشرده ارائه می‌شود.

# ۸. منابع و مطالعهٔ تکمیلی

## منبع اصلی جلسه

- مقالهٔ `Vibe Coding Agent Security and Evaluation` — ترجمهٔ کامل فارسی در همین پوشه.

## مطالعهٔ تکمیلی

- راهنماهای صنعتی امن‌سازی کدنویسی شهودی و گزارش‌های تحلیل تهدید دربارهٔ سوءاستفاده از نام‌های توهمی.

- مستندات `OpenTelemetry` برای ردیابی عامل‌ها؛ به‌ویژه دامنه‌های نشست، تفکر و ابزار.
- بنچمارک‌های استاندارد عامل‌های کدنویسی و بحث بیش‌برازش بنچمارک.
- الزامات مقرراتی مربوط به سامانه‌های هوش مصنوعی پرمخاطره و ارزیابی اثر الگوریتمی.

**پیش‌نمای جلسهٔ پنجم**

جلسهٔ پایانی همهٔ این‌ها را در یک گردش‌کار تولیدی جمع می‌کند: توسعهٔ مبتنی بر مشخصات، بازبینی کد در مقیاس خروجی عامل، و آنچه لازم است تا نمونهٔ اولیه به نرم‌افزاری بدل شود که بشود به آن تکیه کرد.

---